Actividad III

Del incidente a la recuperación

Curso: Criptografía **Trabajo en parejas**

Qué debe construir

Construya una aplicación en Python que cubra el ciclo de un incidente de ransomware: infección, intercambio de una semilla maestra, cifrado de archivos, almacenamiento y recuperación. Elija uno de los modelos de la tabla. Demuestre dos vías de recuperación: por pago y por investigación. Después, incorpore un intermediario MITM y una defensa mediante firmas digitales.

Esta actividad es una **simulación en un laboratorio propio y aislado**. Use máquinas virtuales o contenedores para separar víctima y servidor, conectados mediante una red interna. Trabaje con copias de archivos creados para la práctica y conserve los originales aparte. La infección comienza al ejecutar explícitamente la aplicación; el pago es un evento del protocolo, sin dinero real. La práctica no incluye propagación ni arranque automático.

Los modelos A y B

Modelo	Quién genera la maestra	Entrega inicial
A	El servidor.	La envía protegida a la víctima.
B	La víctima.	La envía protegida al servidor.

Esta es la diferencia entre los modelos. En ambos, el servidor guarda la maestra asociada a la víctima y esta deriva localmente las claves de sus archivos. Cada víctima tiene **un solo incidente**, identificado por id_V, que se conserva durante el cifrado y la recuperación.

Material de referencia y trabajo autónomo

Apóyese en el cuaderno *Colab 1: RSA, fundamentos, ataques y cifrado híbrido*, especialmente en las secciones 7 (RSA-OAEP) y 8 (aplicación cliente-servidor). Adapte sus operaciones criptográficas y su comunicación a los flujos del enunciado. En el informe, explique qué partes utilizó y qué modificó.

El único código suministrado es `generador_semillas.py`. Usted desarrolla la víctima, el servidor, los mensajes, el almacenamiento, la recuperación, el intermediario y la autenticación. Puede elegir la organización del código, los formatos y la interfaz; una aplicación por terminal es suficiente.

Generación de la maestra

```
from generador_semillas import generar_semilla_maestra
s_V = generar_semilla_maestra()
```

Use el módulo sin cambios. La función no recibe argumentos y devuelve 32 bytes. Llámela una vez por víctima, en el participante que corresponda a su modelo. Utilice solo el valor devuelto: no guarde ni transmita las variables internas del generador.

Notación

Símbolo	Significado
id_V, s_V	Identificador y semilla maestra de la víctima.
(pk_V, sk_V)	Claves RSA pública y privada de la víctima para el cifrado.
(pk_S, sk_S)	Claves RSA pública y privada del servidor para el cifrado.
i, K_i, C_i	Contador, clave y contenido cifrado del archivo i.

Los pasos 1–6 aparecen en la descripción y en los diagramas de A y B. Las flechas representan mensajes y las cajas, operaciones locales.

Del inicio al cifrado persistente

Prepare las copias de trabajo y decida cómo identificará cada archivo. El siguiente recorrido es común a ambos modelos, salvo la entrega del paso 2.

1. Iniciar y registrar

Ejecute víctima y servidor. Cada participante prepara y guarda su par RSA. La víctima asigna id_V, lo conserva y envía al servidor una solicitud de registro con ese identificador y pk_V. El servidor responde con pk_S. Las claves privadas permanecen en sus respectivos participantes.

Todos los mensajes del incidente deben poder asociarse con id_V. El servidor mantiene un registro por víctima; repetir el registro no debe crear otra maestra ni habilitar una segunda entrega inicial.

2. Establecer la maestra

En **A**, el servidor genera s_V, la guarda bajo id_V junto a pk_V y envía $\mathrm{OAEP.Enc}(pk_V, s_V)$. La víctima obtiene la maestra con sk_V y confirma su recepción.

En **B**, la víctima genera s_V y envía $\mathrm{OAEP.Enc}(pk_S, s_V)$. El servidor la obtiene con sk_S, la guarda bajo id_V junto a pk_V y confirma la recepción.

Al terminar, la víctima dispone de s_V en memoria y el servidor conserva la misma maestra y el estado del pago. Si el intercambio falla, informe el error y detenga el inicio del cifrado.

3. Cifrar y guardar cada archivo

Asigne contadores distintos $i = 0, 1, 2, \ldots$ y calcule localmente

$$K_i = \mathrm{HMAC}_{\mathrm{SHA256}}(s_V, \mathrm{codificar}_8(i)).$$

Aquí s_V es la clave de HMAC y el contador es su mensaje, codificado en ocho bytes en orden *big-endian*. La salida tiene 32 bytes y se utiliza directamente como clave AES. No se solicita al servidor una clave por archivo.

Cifre cada copia con AES-GCM. Guarde el contenido cifrado C_i, el nonce, la etiqueta y los metadatos que identifiquen el archivo y su contador. Incluya id_V e i en los datos asociados (AAD); documente su codificación para reconstruirlos al descifrar. El formato debe permitir leer todos los campos sin ambigüedad.

Use RSA de al menos 2048 bits con OAEP y SHA-256; y AES-256-GCM con nonce de 12 bytes y etiqueta de 16 bytes. Para claves RSA y nonces, use la aleatoriedad de las bibliotecas. No repita un nonce con la misma clave.

4. Cerrar y reiniciar

Cierre ambos procesos y vuelva a iniciarlos. La víctima debe cargar id_V, su par RSA y las salidas cifradas. El servidor debe cargar su par RSA y, por víctima, s_V, pk_V y el estado del pago.

La víctima no guarda s_V, las claves K_i ni la entrega OAEP inicial: conservar esa entrega permitiría, en A, obtener de nuevo la maestra con sk_V. El reinicio no genera otra maestra ni vuelve a registrar el incidente. La recuperación debe funcionar a partir de los datos que permanecen en disco.

Recuperación e investigación

Las dos vías del paso 5 parten de copias del mismo conjunto cifrado, con el mismo id_V, después del cierre de los procesos. Ejecútelas por separado para que una no proporcione la solución de la otra.

5a. Recuperar la maestra mediante el pago

La víctima solicita la recuperación con id_V y el protocolo registra el evento de pago. El servidor actualiza el estado de esa víctima, carga la maestra existente y devuelve

$$\mathrm{OAEP.Enc}(pk_V, s_V).$$

Debe utilizar la clave pública guardada en el registro; la petición de recuperación no puede reemplazarla por otra. La víctima obtiene s_V con su clave privada sk_V y continúa con el paso 6. Este procedimiento es el mismo en A y B.

5b. Recuperar la maestra mediante investigación

Apague el servidor. Estudie el código del generador suministrado y la derivación de las claves para diseñar e implementar un procedimiento que recupere s_V. El algoritmo de recuperación forma parte de su trabajo.

Información	Condición de uso
Código y salidas cifradas	Puede usar el código de la aplicación y del generador, los archivos cifrados, nonces, etiquetas y metadatos públicos.
Secretos y otras vías	No puede usar la base del servidor, claves privadas, maestras o claves guardadas durante el cifrado, variables internas observadas del generador ni material obtenido por pago o MITM.
Archivos originales	Se reservan para la comparación final; no se utilizan para dirigir la investigación.

Justifique cómo reconoce una maestra correcta. La verificación GCM del paso 6 permite comprobar un descifrado, pero usted debe definir cómo obtiene y evalúa las maestras candidatas.

6. Descifrar, verificar y comparar

Para cada salida cifrada, lea su contador y regenere K_i con la fórmula del paso 3. Reconstruya los mismos AAD y use el nonce y la etiqueta guardados para descifrar y verificar GCM.

Una etiqueta inválida implica que el resultado debe rechazarse. Guarde únicamente resultados válidos en una carpeta nueva e informe cualquier archivo que no pueda recuperar. Cuando termine, compare byte a byte los resultados con los originales reservados. Realice esta comprobación tanto en la vía de pago como en la de investigación.

Qué debe explicar y medir

Describa el fundamento de su procedimiento y estime el trabajo necesario para recuperar la maestra. Registre el entorno de ejecución, el tiempo empleado y una medida del trabajo realizado, como el número de candidatos u operaciones examinados.

Compare la estimación con el resultado observado. Distinga el costo de recuperar s_V del costo posterior de descifrar los archivos y explique cómo influye la cantidad de archivos. Incluya el resultado de la comparación final como evidencia de la recuperación.

Modelo A: recorrido completo

Los pasos 1–4 se describen en la página 2 y los pasos 5–6, en la página 3. Las vías 5a y 5b se prueban por separado.

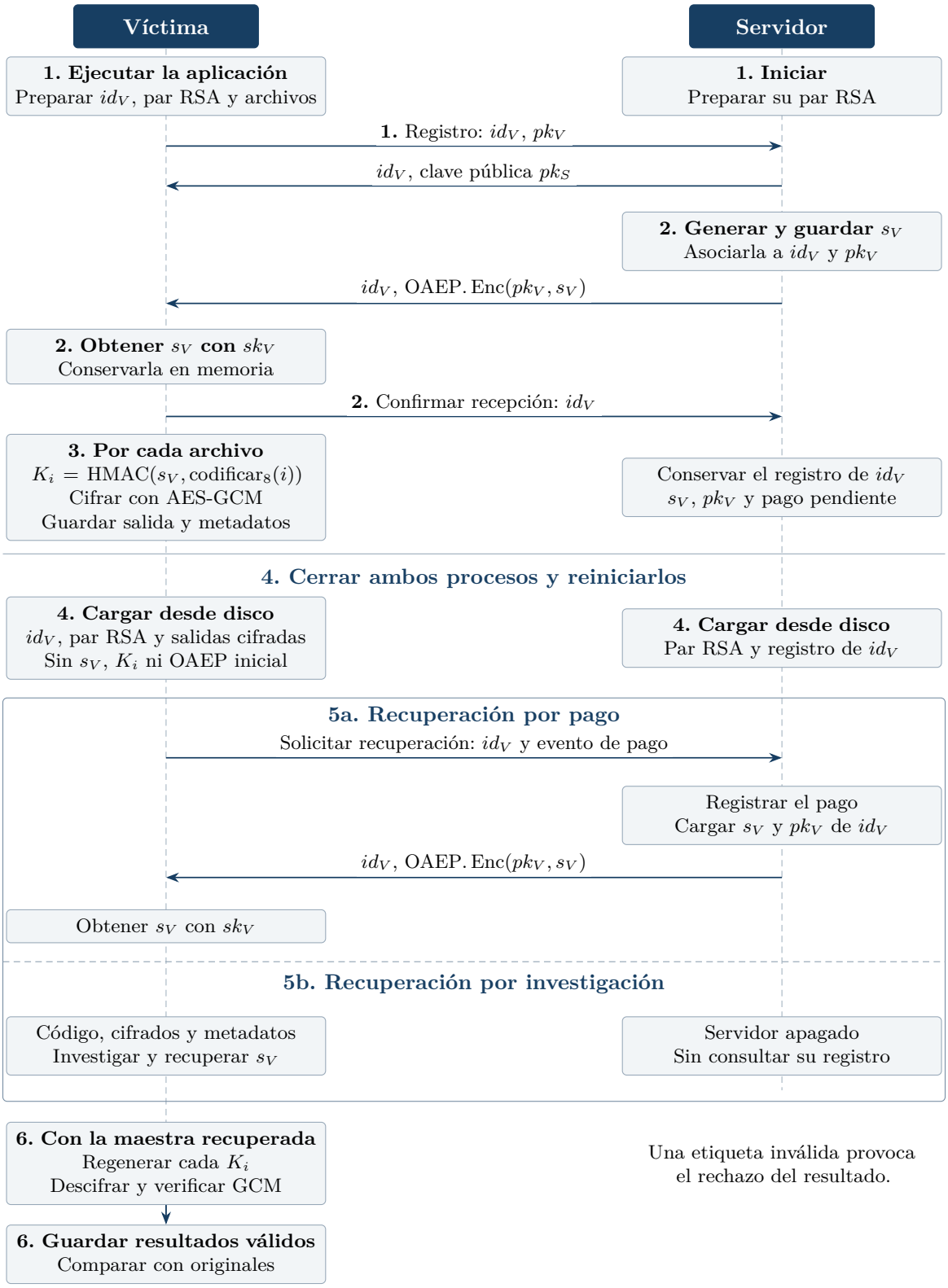


Figura 1. Ciclo completo del modelo A. Ambas vías de recuperación terminan con la misma derivación, verificación y comparación de archivos.

Modelo B: recorrido completo

Los pasos 1–4 se describen en la página 2 y los pasos 5–6, en la página 3. Las vías 5a y 5b se prueban por separado.

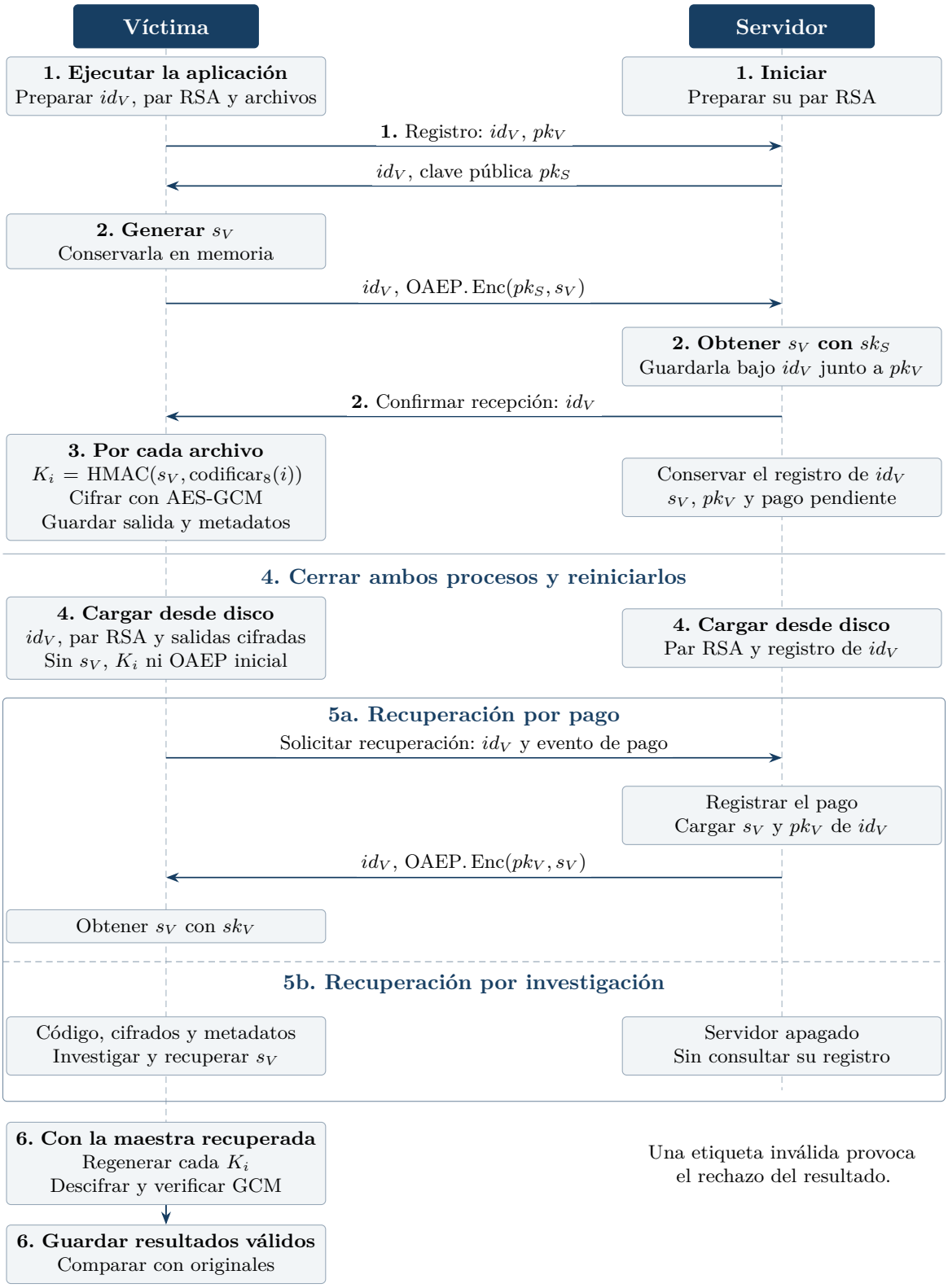


Figura 2. Ciclo completo del modelo B. Ambas vías de recuperación terminan con la misma derivación, verificación y comparación de archivos.

Intermediario MITM

Construya una tercera aplicación que actúe como intermediario (*man in the middle*, MITM) en el modelo elegido. Debe obtener la maestra durante su entrega inicial y permitir que la víctima complete el cifrado.

M1. Preparar las conexiones

Configure a la víctima para conectarse con el intermediario y a este para conectarse con el servidor. Así, todos los mensajes pasan por él. Use una víctima nueva y genere para el intermediario el par RSA (pk_M, sk_M).

M2. Sustituir una clave pública

En esta primera prueba, víctima y servidor aceptan las claves recibidas sin comprobar a quién pertenecen. El intermediario conserva la clave legítima y sustituye la que se usará para proteger la maestra:

Modelo	Sustitución	Clave que conserva
A	Envía pk_M al servidor en lugar de pk_V.	pk_V, para reenviar la maestra a la víctima.
B	Envía pk_M a la víctima en lugar de pk_S.	pk_S, para reenviar la maestra al servidor.

Mantenga id_V y reenvíe sin cambios la otra clave pública. En A, el servidor guarda pk_M creyendo que pertenece a la víctima. En B, la víctima utiliza pk_M creyendo que pertenece al servidor.

M3. Obtener la maestra y reenviarla

El emisor cifra s_V con la clave sustituida. El intermediario recibe esa entrega, la descifra con sk_M y conserva la maestra. Luego cifra la **misma** s_V con la clave del destinatario legítimo: pk_V en A o pk_S en B. Reenvíe esta nueva entrega. El destinatario debe poder abrirla con su propia clave privada.

M4. Completar el intercambio

Reenvíe la confirmación de recepción al emisor original. En A, la envía la víctima después de obtener s_V. En B, la envía el servidor después de obtener y guardar s_V bajo id_V. Ambos participantes deben terminar con la misma maestra.

M5. Completar el cifrado

La víctima deriva las claves y guarda las salidas cifradas como en el paso 3. Cierre víctima y servidor y compruebe que esas salidas permanecen en disco. El intermediario conserva la maestra obtenida en M3.

M6. Recuperar los archivos sin pago

Facilite al intermediario copias de las salidas cifradas y sus metadatos, como entrada de la prueba y fuera del protocolo. Con la maestra interceptada, debe regenerar las claves, descifrar, verificar GCM y comparar los resultados con los originales. El servidor permanece apagado.

Qué debe observar

Identifique en las trazas la sustitución, la apertura y el reenvío de la maestra, y la confirmación final. Explique por qué RSA-OAEP no impidió este resultado. Esta prueba utiliza la maestra interceptada; es independiente de la investigación del paso 5b. Después, incorpore la defensa de la página 9.

MITM en el modelo A

Los pasos M1–M6 corresponden a la página 6. El intermediario conserva la clave legítima recibida en M2 y sustituye la indicada.

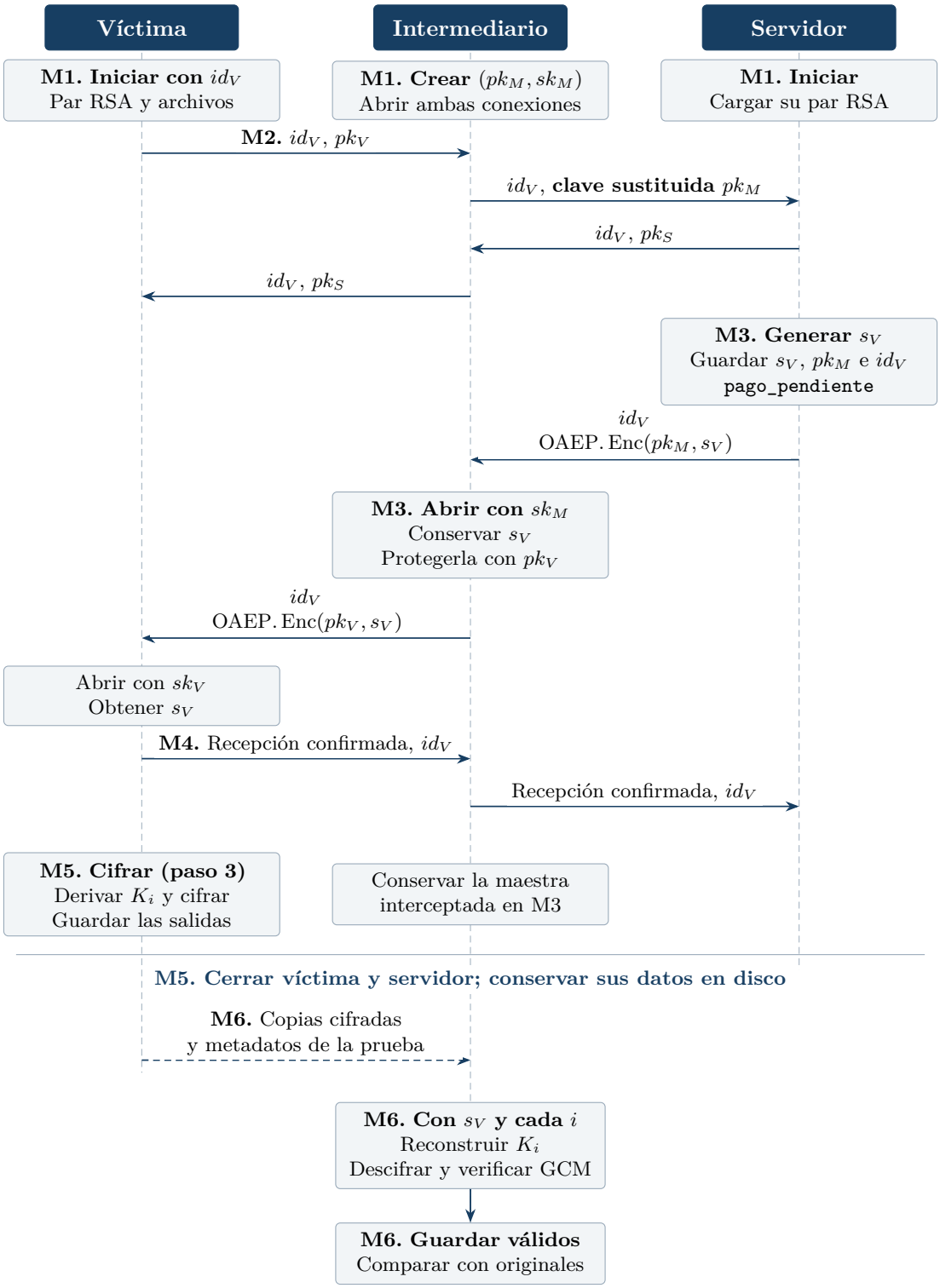


Figura 3. El intercambio continúa con la misma maestra. La flecha discontinua representa las copias facilitadas para la prueba, fuera del protocolo.

MITM en el modelo B

Los pasos M1–M6 corresponden a la página 6. El intermediario conserva la clave legítima recibida en M2 y sustituye la indicada.

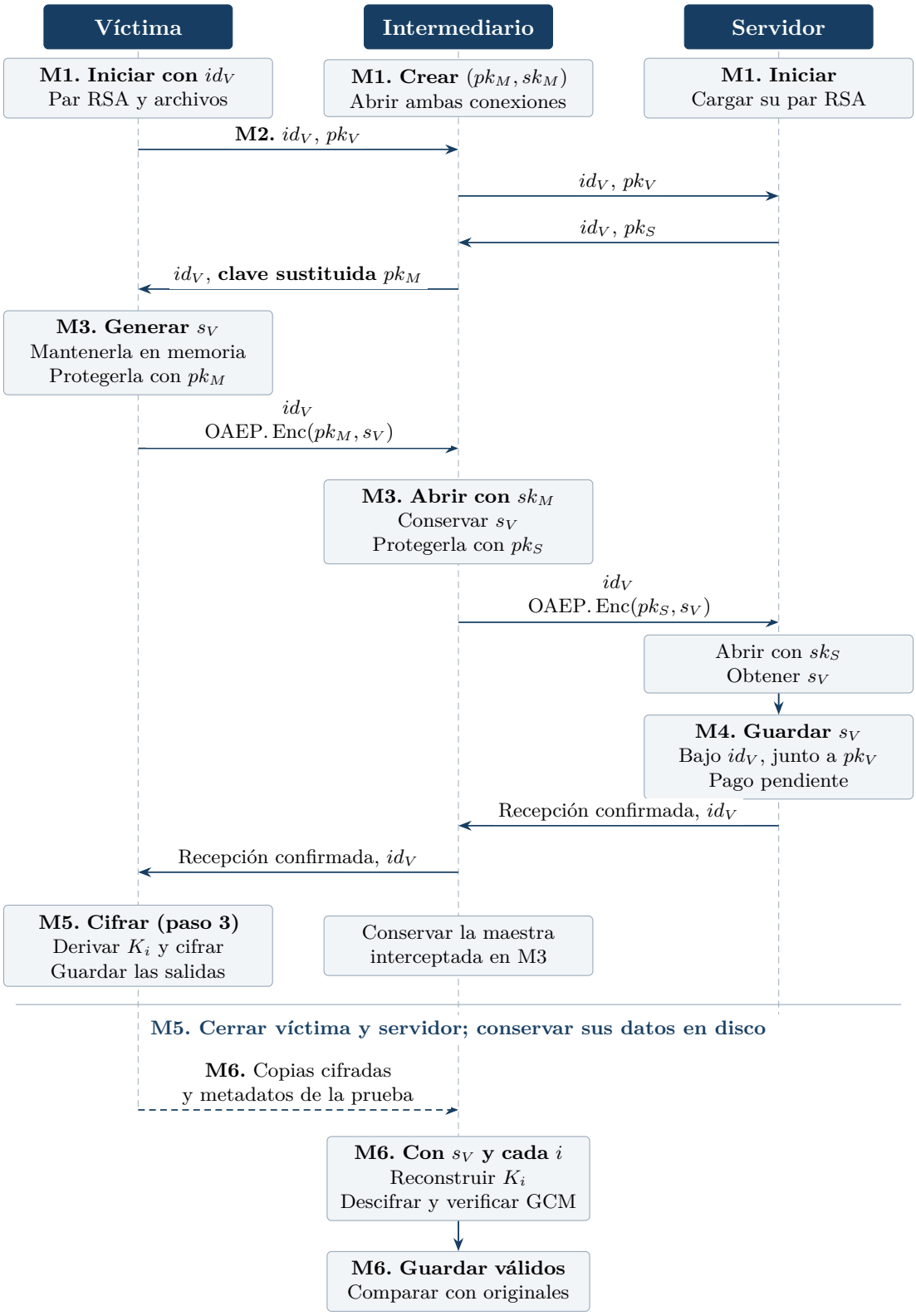


Figura 4. El intercambio continúa con la misma maestra. La flecha discontinua representa las copias facilitadas para la prueba, fuera del protocolo.

Autenticación mediante firmas digitales

Investigue e implemente una defensa que impida la sustitución de claves públicas mediante **firmas digitales**. Usted elige y justifica el diseño; el enunciado establece qué debe lograr.

Una firma permite verificar datos con una clave pública. Para atribuirla a un participante, también debe existir una razón para confiar en que esa clave de verificación le pertenece. Si el intermediario puede reemplazar tanto los datos como la clave que verifica la firma, no se ha resuelto la suplantación.

Qué debe decidir

Describa estas decisiones antes de presentar los resultados:

1. **Esquema de firma.** Elija uno disponible en una biblioteca criptográfica. Explique quién firma, quién verifica y qué claves utiliza cada participante. Distinga las funciones de firma y cifrado.
2. **Datos firmados.** Defina exactamente qué información se firma y cómo se representa. Justifique cómo la firma permite vincular la clave RSA recibida con la identidad esperada y, cuando corresponda, con id_V.
3. **Confianza en la verificación.** Explique cómo obtiene cada participante las claves de verificación legítimas y por qué el intermediario no puede reemplazarlas por las suyas. Identifique qué información debe conocerse antes del intercambio.
4. **Momento de la comprobación.** Indique dónde se verifica la firma y qué hace la aplicación cuando falla. Las comprobaciones necesarias deben completarse antes de utilizar una clave recibida para enviar la maestra.

Cómo incorporarlo a la aplicación

La víctima debe poder autenticar la clave del servidor y el servidor la de la víctima. Una firma ausente o inválida, una identidad incorrecta o una clave de verificación sin confianza deben detener el intercambio.

Mantenga RSA-OAEP para proteger la maestra. La firma no sustituye ese cifrado. Conserve la información de confianza necesaria para que la aplicación funcione después del reinicio y respete la asociación entre id_V y la clave registrada durante la recuperación por pago.

Adapte el diagrama del modelo elegido: añada los datos firmados, las verificaciones y el punto de rechazo. El ciclo de los pasos 1–6 debe seguir siendo reconocible. El diseño de esos mensajes forma parte de su investigación.

Cómo comprobar la defensa

Repita la prueba con una víctima nueva y el mismo intermediario. Muestre que la sustitución de M2 se detecta **antes de enviar la maestra protegida con la clave sustituida**. Identifique la comprobación que falla y el mensaje que ya no se envía.

Compruebe también que una firma producida por el intermediario con sus propias claves no se acepta como legítima, aunque adjunte su clave de verificación. Finalmente, ejecute el intercambio con los participantes legítimos y demuestre que permite completar el cifrado, el reinicio y la recuperación por pago.

En el informe, explique por qué su diseño rechaza la sustitución, por qué confiar solamente en la firma recibida sería insuficiente y qué protección añade respecto a RSA-OAEP.

Comprobación y entrega

Pruebas que debe completar

Presente evidencias de estas cuatro pruebas para el modelo elegido. Pueden ser trazas, capturas o resultados guardados por su programa. Identifique los pasos de los diagramas a los que corresponden.

Prueba	Resultado que debe demostrar
Cifrado y pago	Los archivos cifrados permanecen en disco. Tras cerrar y reiniciar ambos procesos, el pago permite recuperar la maestra y los archivos originales.
Investigación	Con el servidor apagado y solo las entradas permitidas, recupera el mismo conjunto cifrado. Explica el procedimiento y compara el costo estimado con el medido.
MITM	El intermediario obtiene la maestra en la entrega inicial, permite completar el cifrado y recupera las copias sin pago.
Firmas digitales	Rechaza la sustitución y la firma del intermediario antes de exponer la maestra. El intercambio legítimo permite completar el ciclo.

Archivos que debe entregar

Entregue un ZIP con:

- **Código de la aplicación**, incluido `generador_semillas.py` sin cambios.
- **Instrucciones de ejecución**: dependencias, preparación del entorno y comandos para repetir las cuatro pruebas. Explique cómo crear los archivos de trabajo y separar los datos de cada prueba.
- **Informe en PDF**, con las explicaciones y evidencias indicadas a continuación.

Contenido del informe

Explique cómo construyó la aplicación: modelo elegido, componentes, mensajes y datos que persisten. Relacione su código con los pasos del diagrama e identifique qué adaptó del material de referencia.

Describa la investigación del paso 5b, sus mediciones y resultados. Para el MITM, identifique la clave sustituida y cómo se obtuvo la maestra. Para la defensa, justifique el diseño de firmas, la confianza en las claves de verificación y el rechazo del intermediario; incluya su diagrama adaptado.

Muestre la comparación de los archivos recuperados con los originales en las vías correspondientes. Cite las fuentes utilizadas y adjunte las evidencias que respalden sus conclusiones. No necesita entregar imágenes completas de las máquinas virtuales. **No hay sustentación oral.**

Evaluación

Criterio	Peso
Modelo criptográfico y ciclo completo de la aplicación	25 %
Persistencia y funcionamiento después del reinicio	15 %
Investigación, recuperación y análisis del costo	25 %
MITM, firmas digitales y explicación de resultados	20 %
Pruebas, instrucciones e informe	15 %
Total	**100 %**